Assignment 4 - Preparing for a Successful CMMC Audit

Simulate a pre-audit preparation by selecting a C3PAO, reviewing controls, and conducting an internal mock audit based on the provided checklist.

Instructions:

This assignment helps you prepare for a formal CMMC audit by walking through key preparation steps. You will act as a compliance coordinator reviewing final readiness across documentation, tooling, and personnel.

Use the following checklist categories to assess your readiness:

- C3PAO engagement
- Audit documentation review
- Mock audit practices
- Interview preparedness
- Control evidence completeness

Scenario:

Your company has finalized most cybersecurity implementations for CMMC Level 2 and has a target audit scheduled in two months. You have received a pre-audit readiness checklist from your internal compliance lead. The checklist reveals:

- The C3PAO has not yet been selected.
- Incident response logs are incomplete for the past quarter.
- Evidence folders are 90% complete, but some policies lack final approval.
- Technical teams have not been trained for audit interviews.
- No internal mock audit has been conducted in the past 12 months.

Questions for this assignment

Tasks:

1. What should be your first action, and why?

2. How can you validate evidence completeness before the audit?

3. What three elements should be reviewed in a mock audit?

4. How can your team prepare effectively for interviews with the C3PAO?

5. Suggest a 3-step plan to engage and onboard a C3PAO.

Solution by the Instructor:

Tasks:

1. What should be your first action, and why?

2. How can you validate evidence completeness before the audit?

3. What three elements should be reviewed in a mock audit?

4. How can your team prepare effectively for interviews with the C3PAO?

5. Suggest a 3-step plan to engage and onboard a C3PAO.

Sample Solution:

1. First action: Select and contract a C3PAO; without it, scheduling and audit coordination cannot begin.
2. Use a documented checklist to review each control's evidence folder and flag missing approvals.
3. Review policy coverage, system configurations, and incident response logs.
4. Conduct audit interview simulations with role-based Q&A and documentation review.
5. Step 1: Shortlist C3PAOs from the DoD marketplace. Step 2: Evaluate their availability and scope. Step 3: Sign engagement agreement and define timelines.